

PENETRATION TESTING REPORT

FAWAZ ABDUL AZEEZ

1. Engagement Overview

Target System	Linux-Based Web Application Server
Target IP	172.20.10.3
Assessment Environment	Controlled Internal Network
Environment	Controlled Internal Lab Network
Classification	Confidential
Engagement Type	Black Box
Report Date	April 2026

2. Confidentiality Notice

This report contains sensitive security information obtained during a controlled penetration testing assessment conducted for academic purposes. It is intended solely for authorized academic evaluation.

Unauthorized access, disclosure, or distribution of this document, in whole or in part, is strictly prohibited. The findings presented reflect the security posture of the system at the time of testing and may change as configurations are updated.

This report does not guarantee complete security. Continuous monitoring, regular assessments, and timely remediation are essential to maintain an adequate security posture. Any misuse of the information contained in this report is strictly discouraged and may lead to security risks.

3. Executive Summary

This report presents the results of a penetration testing assessment conducted on a Linux-based web server within a controlled internal lab environment. The primary objective of the engagement was to identify security vulnerabilities, evaluate their potential impact, and demonstrate how they could be exploited in a real-world attack scenario.

The assessment revealed multiple security weaknesses across network services, authentication mechanisms, and web application components. These vulnerabilities were not isolated; rather, they could be combined to form a structured attack path, enabling progression from initial access to full system compromise.

Critical issues identified during the assessment include weak authentication controls, misconfigured services, insecure file upload functionality, and the presence of exploitable vulnerabilities that allow remote code execution and privilege escalation. The successful exploitation of these weaknesses demonstrates a significant risk to the confidentiality, integrity, and availability of the system.

Overall, the security posture of the target system is assessed as high risk. Immediate remediation of critical and high-severity vulnerabilities is strongly recommended, along with the implementation of stronger security controls, regular patch management, and continuous monitoring to reduce future risk.

3.1 Overall Risk Rating

Critical	High	Medium	Low	Info	Total
4	2	2	1	0	9

3.2 Key Findings Summary

- Unauthorized access to network services due to improper configuration and lack of access controls
- Successful compromise of user credentials through brute-force attacks, highlighting weak password policies
- Exposure of administrative interfaces without sufficient protection or restriction mechanisms
- Remote code execution achieved through insecure file upload functionality within the web application
- Privilege escalation from a low-privileged user to root-level access, resulting in full system control
- Unauthorized access to the backend database via a web interface, leading to potential data exposure

3.3 Risk Mitigation Strategy

The identified vulnerabilities should be addressed using a risk-based approach, prioritizing critical and high-severity issues that directly impact system security. Immediate mitigation efforts should focus on eliminating remote code execution vulnerabilities, securing authentication mechanisms, and preventing unauthorized access to administrative interfaces.

In addition to immediate fixes, long-term mitigation strategies should include system hardening, regular patch management, and continuous monitoring. Implementing layered security controls such as firewalls, intrusion detection systems, and access restrictions will further reduce the likelihood of successful attacks.

4. Scope and Methodology

4.1 Engagement Scope

Target / IP Range	Description	Status
172.20.10.3	Linux Web Server	In Scope
172.20.10.0/24	Internal Network	In Scope
Web Application	WordPress instance and Admin interface	In Scope

4.2 Methodology

The testing process followed a structured methodology aligned with the guidelines of OWASP and the Penetration Testing Execution Standard framework. These standards provide a comprehensive approach for identifying, analyzing, and validating security vulnerabilities across network services, system configurations, and web applications. The assessment was conducted in a controlled and consistent manner, starting with reconnaissance to gather information about the target environment, followed by scanning and enumeration to identify active services and potential entry points. This was then followed by vulnerability analysis and controlled exploitation to validate the impact of identified weaknesses.

Post-exploitation activities were performed to assess the extent of system compromise, including privilege escalation and access to sensitive resources. This structured approach ensured thorough coverage of the attack surface while simulating realistic attack scenarios.

	Phase	Activities
1	Reconnaissance	Identification of active hosts within the network using ARP scanning techniques to map the target environment
2	Scanning & Enumeration	Port scanning using Nmap, service identification, and detailed enumeration of FTP, SMB, and HTTP services
3	Vulnerability Analysis	Analysis of identified services to detect misconfigurations, weak authentication mechanisms, and exposed resources
4	Exploitation	Execution of brute-force attacks using Hydra, compromise of CMS components, file upload exploitation, and use of exploits via searchsploit and Metasploit Framework
5	Post-Exploitation	Establishment and management of sessions using Meterpreter, privilege escalation, and internal system enumeration
6	Data Access & Validation	Extraction and validation of sensitive data, including credential harvesting and database access through web interfaces such as phpMyAdmin
7	Documentation & Reporting	Compilation of findings, risk evaluation, and formulation of remediation recommendations

4.3 Tools and Testing Environment

The assessment was conducted using a combination of industry-standard tools across different phases of the penetration testing lifecycle.

Reconnaissance

- arp-scan – Host discovery within the internal network

Scanning & Enumeration

- Nmap – Port scanning and service identification
- ftp – FTP service interaction and access testing
- SMBclient – SMB share enumeration and file access

Web Enumeration

- DirBuster – Directory and endpoint discovery
- WPScan – CMS user and vulnerability enumeration

Credential Attacks

- Hydra – Brute-force authentication attacks

Vulnerability Research

- searchsploit – Identification of relevant public exploits

Exploitation

- Metasploit Framework – Exploit execution and session establishment

Post-Exploitation

- Meterpreter – Interactive shell access and system control
- Linux CLI Tools – System enumeration and sensitive file analysis
- phpMyAdmin – Database access and data extraction

Platform

- Kali Linux – Primary testing environment

5. Findings Summary

#	Finding Title	Severity	CVSS	Affected Host	Status
F-001	Misconfigured FTP Service	HIGH	7.5	172.20.10.3	Open
F-002	SMB Share Exposure	MEDIUM	6.5	172.20.10.3	Open
F-003	Weak Authentication	CRITICAL	9.0	172.20.10.3	Open
F-004	Admin Interface Exposure	HIGH	8.5	172.20.10.3	Open
F-005	Insecure File Upload (RCE)	CRITICAL	9.5	172.20.10.3	Open
F-006	Remote Code Execution (Exploit)	CRITICAL	10.0	172.20.10.3	Open
F-007	Privilege Escalation to Root	CRITICAL	10.0	172.20.10.3	Open
F-008	Database Exposure	MEDIUM	6.8	172.20.10.3	Open
F-009	Lack of Logging & Monitoring	LOW	4.0	172.20.10.3	Open

6. Detailed Findings

Finding F-001: Misconfigured FTP Service

Severity	HIGH	CVSS Score	7.5
Affected Host	172.20.10.3		
Port / Service	21/tcp — FTP		

Description

During the scanning and enumeration phase, the FTP service running on the target system was identified as improperly configured. The service allowed access without enforcing strict authentication requirements, effectively permitting unauthenticated users to connect and interact with files stored on the server. This type of misconfiguration is commonly observed in poorly secured environments and can serve as an initial entry point for attackers.

Impact:

Unauthorized access to the FTP service can lead to exposure of sensitive files, including configuration data, credentials, or application-related information. Such data can be leveraged to gain deeper insight into the system and facilitate further exploitation, including credential reuse and lateral movement.

Evidence Summary:

The FTP service was accessed without valid credentials, and files were successfully listed and retrieved, confirming the absence of proper access control mechanisms.

Recommendation:

Disable anonymous FTP access and enforce authentication for all users. Additionally, implement proper access control policies, restrict directory permissions, and enable logging to monitor access attempts.

Finding F-002: SMB Share Exposure

Severity	MEDIUM	CVSS Score	6.5
Affected Host	172.20.10.3		
Port / Service	445 — SMB		

Description

The SMB service was found to expose shared directories with insufficient access restrictions. Enumeration revealed that certain shares could be accessed without proper authentication, allowing unauthorized users to browse and retrieve files from the system.

Impact:

Exposure of SMB shares can result in unintended disclosure of sensitive information. Attackers may use this information to map the internal structure of the system, identify valid usernames, and gather data that can support further attacks such as credential compromise or privilege escalation.

Evidence Summary:

SMB shares were successfully enumerated and accessed, and files were retrieved without encountering access restrictions.

Recommendation:

Restrict SMB share access using authentication and proper permission settings. Disable unnecessary shares and apply the principle of least privilege to limit exposure.

Finding F-003: Weak Authentication

Severity	CRITICAL	CVSS Score	9.0
Affected Host	172.20.10.3		
Port / Service	22/tcp — SSH		

Description:

The system was found to rely on weak authentication mechanisms, including poor password policies and the absence of account lockout protections. This allowed brute-force attacks to be performed successfully using automated tools, resulting in the discovery of valid user credentials.

Impact:

Compromised credentials enable attackers to gain legitimate access to system services and applications. This significantly increases the risk of further exploitation, as attackers can operate within the system with minimal detection and escalate their privileges.

Evidence Summary:

A brute-force attack was conducted, resulting in the successful identification of valid credentials, which were then used to authenticate into the system.

Recommendation:

Implement strong password policies, including complexity and length requirements.

Enable account lockout mechanisms and consider multi-factor authentication to prevent unauthorized access.

Finding F-004: Admin Interface Exposure

Severity	HIGH	CVSS Score	8.5
Affected Host	172.20.10.3		
Port / Service	12380/tcp — HTTP (WordPress)		

Description:

During web enumeration, the administrative interface of the web application was discovered. Using previously compromised credentials, the tester was able to successfully authenticate into the admin panel. The application lacked additional security controls such as IP restrictions or multi-factor authentication.

Impact:

Administrative access provides full control over the web application, including the ability to modify content, manage users, and upload files. This significantly increases the risk of further exploitation and system compromise.

Evidence Summary:

The administrative panel was accessed using valid credentials, and full functionality was available without restrictions.

Recommendation:

Restrict access to administrative interfaces, enforce strong authentication controls, and implement multi-factor authentication.

Finding F-005: Insecure File Upload (RCE)

Severity	CRITICAL	CVSS Score	9.5
Affected Host	172.20.10.3		
Port / Service	HTTP — WordPress		

Description:

The web application allowed file uploads without performing proper validation of file type or content. This weakness enabled the upload of a malicious file containing executable code, which was subsequently executed on the server.

Impact:

This vulnerability allows attackers to execute arbitrary commands on the system, potentially leading to full system compromise. It is one of the most critical vulnerabilities in web applications.

Evidence Summary:

A malicious file was uploaded successfully and executed on the server, resulting in command execution.

Recommendation:

Implement strict file validation, restrict executable permissions, and store uploaded files outside the web root.

Finding F-006: Remote Code Execution (Exploit)

Severity	CRITICAL	CVSS Score	10.0
Affected Host	172.20.10.3		
Port / Service	Multiple (Web Application / Exploited Service)		

Description:

A known vulnerability affecting one of the services on the target system was identified and exploited using publicly available exploit code. The exploit was executed successfully, resulting in remote access to the system.

Impact:

Remote code execution enables attackers to gain complete control over the system without requiring prior authentication. This represents a severe security risk.

Evidence Summary:

The exploit was executed, and a remote session was established successfully.

Recommendation:

Apply security patches, update vulnerable services, and minimize exposure of critical services.

Finding F-007: Privilege Escalation to Root

Severity	CRITICAL	CVSS Score	10.0
Affected Host	172.20.10.3		
Port / Service	Local System		

Description:

Following initial access, a local privilege escalation vulnerability was identified within the system. By exploiting this weakness, it was possible to elevate privileges from a low-privileged user account to root-level access. This indicates insufficient restriction of system-level permissions and potential presence of unpatched vulnerabilities or misconfigured binaries.

Impact:

Root-level access grants complete administrative control over the system. An attacker can modify system configurations, access all sensitive files, establish persistence mechanisms, and potentially compromise other connected systems within the environment.

Evidence Summary:

Post-exploitation activities confirmed successful escalation to root privileges, with unrestricted access to critical system resources.

Recommendation:

Apply all relevant system patches, review SUID/permission configurations, and enforce the principle of least privilege. Regular audits should be conducted to identify and remediate privilege escalation vectors.

Finding F-008: Unauthorized Database Access via Web Interface

Severity	MEDIUM	CVSS Score	6.8
Affected Host	172.20.10.3		
Port / Service	12380/tcp — HTTP (phpMyAdmin)		

Description:

The database management interface was accessible using previously compromised credentials, allowing direct interaction with the backend database. The interface lacked additional access restrictions, enabling unauthorized viewing and extraction of stored data.

Impact:

Exposure of database contents can result in leakage of sensitive information such as user credentials, application data, and configuration details. This information can be leveraged for further attacks, including credential reuse and data manipulation.

Evidence Summary:

The database interface was successfully accessed, and data retrieval operations were performed without restriction.

Recommendation:

Restrict access to database management interfaces to authorized users and networks only. Enforce strong authentication, secure stored credentials, and disable unnecessary public exposure.

Finding F-009: Lack of Security Logging and Monitoring

Severity	LOW	CVSS Score	4.0
Affected Host	172.20.10.3		
Port / Service	System-wide		

Description:

The system lacked adequate logging and monitoring mechanisms to track and detect suspicious activities. During the assessment, no alerts or logs were generated in response to scanning, exploitation, or privilege escalation attempts, indicating limited visibility into system events.

Impact:

Without proper logging and monitoring, security incidents may go undetected for extended periods. This significantly increases the risk of prolonged unauthorized access, data breaches, and delayed incident response.

Evidence Summary:

No evidence of logging or alerting mechanisms was observed during multiple stages of the attack simulation.

Recommendation:

Implement centralized logging and monitoring solutions, such as SIEM or intrusion detection systems. Ensure logs are regularly reviewed and retained for incident response and forensic analysis.

7. Remediation Roadmap

The following table provides a prioritized remediation roadmap based on the severity of identified vulnerabilities. Immediate attention should be given to Critical and High severity findings to reduce the overall risk exposure.

ID	Finding	Severity	SLA (Days)	Owner	Status
F-001	Misconfigured FTP Service	HIGH	7 Days	Infrastructure	Open
F-002	SMB Share Exposure	MEDIUM	7 Days	Infrastructure	Open
F-003	Weak Authentication Mechanism	CRITICAL	Immediate (24h)	Security / IT	Open
F-004	Administrative Interface Exposure	HIGH	3 Days	Web Admin	Open
F-005	Insecure File Upload (Code Execution)	CRITICAL	Immediate (24h)	Web Admin	Open
F-006	Remote Code Execution (Public Exploit)	CRITICAL	Immediate (24h)	Security / IT	Open
F-007	Privilege Escalation to root	CRITICAL	Immediate (24h)	System Admin	Open
F-008	Unauthorized Database Access	MEDIUM	5 Days	Database Admin	Open
F-009	Lack of Logging & Monitoring	LOW	14 Days	Security / IT	Open

8. Conclusion

The penetration test identified a total of 9 vulnerabilities across the assessed environment, including 4 Critical, 2 High, 2 Medium, and 1 Low severity findings. These vulnerabilities collectively pose a significant risk to the confidentiality, integrity, and availability of the target system.

The most critical risks stem from weaknesses in authentication mechanisms, misconfigured network services, and vulnerable web application components that enable remote code execution. These issues were effectively chained together to demonstrate a complete attack path, allowing unauthorized access, execution of arbitrary code, escalation of privileges, and exposure of sensitive data.

The assessment illustrates how an attacker can progress from initial access through exposed services such as FTP and SMB to full system compromise using credential attacks, application-level exploitation, and post-exploitation techniques. The ability to achieve root-level access further emphasizes the severity of the identified vulnerabilities.

It is strongly recommended that all Critical and High severity findings be addressed on a priority basis, followed by remediation of Medium and Low severity issues.

Implementing the recommended security controls will significantly reduce the attack surface and enhance the overall security posture of the environment.

Tester Sign-off

Student Security Analyst	Reviewed By	Date
Fawaz Abdul Azeez	Faculty Supervisor	April 2026